Web security Essentials

Web applications are among the most common entry points for attackers because they are always available and exposed. They often connect to back-end systems like databases and other infrastructure, offering attackers high-impact opportunities. A vulnerable web application is often the first stage in a larger attack sequence

As a Web App Owner	As a Web App User
Your web application is always online and must be secured 24/7	Your data is stored in a web application, potentially insecurely
Anyone around the world can access your app at any time	Once your browser is breached, all of your accounts are at risk
It is challenging to stay up to date with so many emerging threats	A breach can result in identity theft or financial loss
You have the responsibility of securing your users' data	Your privacy can be permanently compromised

In 2017, Equifax's sensitive customer data of nearly 150 million Americans was compromised due to an Apache vulnerability. By abusing this vulnerability, the attackers were able to access internal databases storing valuable customer data.

Request-Response Cycle is the foundation of how the web functions

Attackers can abuse this request-response cycle by overwhelming servers with requests, bypassing access controls, or even tricking the server into executing harmful commands.

Components of a Web Service

- **Application**: The code, images, styles, and icons that dictate how the website looks and functions.
- **Web Server**: This component hosts the application. It listens for requests and returns a response to the user.
- **Host Machine**: The underlying operating system, Linux or Windows, that runs the web server and the application.

Because Web Servers are publicly exposed and handle all incoming web requests, web servers are a common target for attackers.

What does your web browser send to a server to receive a web page?

Request

What web server is most commonly used to host WordPress websites?

Apache

What do we call the OS and environment that runs the web server and application?

Host Machine

Protecting the Web

Protecting the Application

- Secure Coding: Avoid insecure functions, ensure proper handling of errors, and remove sensitive information.
- Input Validation & Sanitization: Validate and sanitize user input to prevent injection attacks.
- Access Control: Restrict access based on user roles.

Protecting the Web Server

- Logging: Keep a detailed record of all web requests with access logs.
- Web Application Firewall (WAF): Filter and block harmful traffic based on defined rules.
- Content Delivery Network (CDN): Reduce direct exposure to your server and use integrated WAFs.

Protecting the Host Machine

- Least Privilege: Use low-privilege users for services.
- System Hardening: Disable unnecessary services and close unused ports.
- Antivirus: Add endpoint-level protection that blocks known malware.

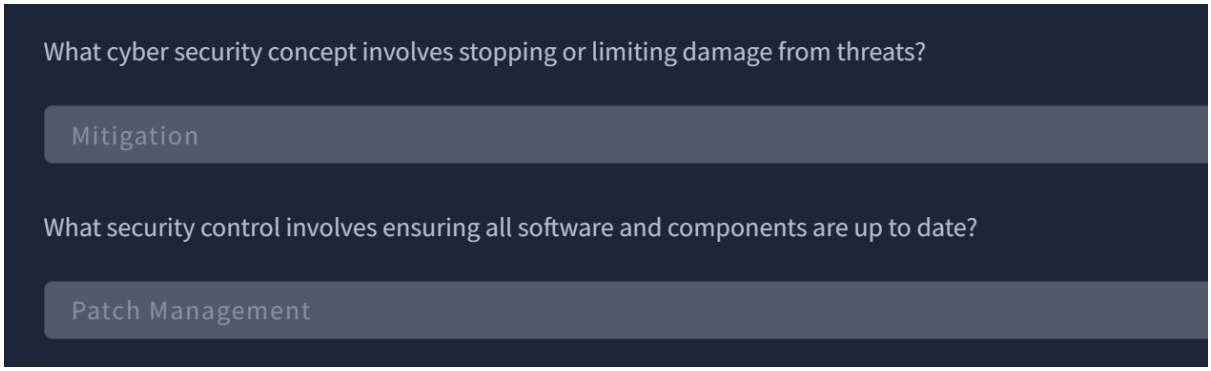
Security Tips for All Three Components

- Strong Authentication: Don't just let anyone access your code, admin panels, or host machine.
- Patch Management: Ensure your app dependencies, web server, and host machine are up to date.

Logging

Websites creates logs for every actions. These will be helpful during investigation. They track information about every interaction with the server, including the client's IP address, timestamp, requested page or data, response status from the server, and user agent.

Ex:



Content Delivery network

CDNs store and serve cached content from servers closer to the user to reduce latency

Security Benefits

- IP Masking: Hides the origin server IP address, which makes it harder for attackers to target.
- DDoS Protection: CDNs can absorb a large amount of traffic, making denial-of-service attacks less effective.
- Enforced HTTPS: Encrypted communication via TLS is enforced by default by most CDNs.
- Integrated WAF: Many CDNs, including Cloudflare CDN, Amazon CloudFront & Azure Front Door, integrate web application firewalls.

Web Application Firewalls

They inspect incoming HTTP traffic and block or log potentially harmful requests based on security rules.

- Cloud-based (Reverse Proxy): Sits in front of the web server. These WAFs are easy to deploy and have great scalability.

- Host-based: Software deployed directly on the web server and offers control for each application.
- Network-based: A physical or virtual appliance situated on the network perimeter. More suited for enterprise environments.

WAF Feature	Detection Method	Example
Signature-Based Detection	Matches known attack patterns or payloads	A request with a User-Agent that matches a known tool, `sqlmap/1.8.1`
Heuristic-Based Detection	Analyzes the context and behavior of requests	A long query string with special characters `search?q=%3Cscript%20(1)`
Anomaly & Behavioral Analysis	Flags deviations from normal traffic behavior	A single IP address makes repeated login attempts in a short period of time
Location & IP Reputation Filtering	Uses location and threat intel to block IPs	A request from an IP address that is outside of your normal business area

Antivirus

They can help detect malicious file uploads, such as web shells, post-exploitation tools, and other malicious software. AVs are just one layer in a broader defense-in-depth strategy and should be combined with other security measures to provide stronger protection.

Which type of Web Application Firewall operates by running on the same system as the application itself?

Host-Based

Which common WAF detection technique works by matching incoming requests against known malicious patterns?

Signature-Based